

SÉRIE : BASES DE DONNÉES

CHAPITRE 8 : SÉCURISATION ET SÉCURITÉ

Interfaçage, Contrôle d'Accès & Transactions



LIVRET D'EXCELLENCE POUR LA RÉUSSITE ABSOLUE —
MATHBACAI.COM

Version 2.0 — Conforme aux normes pédagogiques de l'Inspection Générale

Fiche 1 : Le Cours Complet (Synthèse théorique rigoureuse)
Fiche 2 : Le Recueil de Questions-Réponses corrigées (40 Flashcards
d'Active Recall)
Fiche 3 : Quiz d'Évaluation & Mémentos d'Excellence (10 Questions
types Bac corrigées)

Contents

1	Fiche 1 : Le Cours Complet	2
1.1	Introduction à la Sécurité des Bases de Données (Page 208+)	2
1.2	Les Menaces et Vulnérabilités Majeures	2
1.3	Le Langage de Contrôle de Données (LCD)	2
1.3.1	1. Création d'Utilisateurs	2
1.3.2	2. La commande GRANT (Attribution de Privilèges)	3
1.3.3	3. La commande REVOKE (Retrait de Privilèges)	3
1.3.4	4. La notion de Rôle	3
1.4	Contrôle des Transactions et Concurrency (ACID)	3
1.4.1	Les Propriétés ACID	3
1.4.2	Commandes de Contrôle de Transaction	4
1.5	Sauvegarde, Restauration et Audit	4
1.6	Modélisation Graphique TikZ : Architecture de Sécurité Multicouche	4
2	Fiche 2 : Le Recueil de Questions-Réponses (40 Flashcards)	6
3	Fiche 3 : Quiz d'Évaluation & Fiches Mémo	12
3.1	Quiz d'Évaluation : 10 Questions types du Baccalauréat	12
3.1.1	Question 1 — QCM	12
3.1.2	Question 2 — Vrai ou Faux	12
3.1.3	Question 3 — QCM	12
3.1.4	Question 4 — Vrai ou Faux	12
3.1.5	Question 5 — QCM	13
3.1.6	Question 6 — Vrai ou Faux	13
3.1.7	Question 7 — QCM	13
3.1.8	Question 8 — Vrai ou Faux	13
3.1.9	Question 9 — QCM	13
3.1.10	Question 10 — Vrai ou Faux	13
3.2	Mémento de Synthèse Universelle	14
3.3	Les 5 Règles d'Or pour la Sécurité au Baccalauréat	14

Chapter 1

Fiche 1 : Le Cours Complet

1.1 Introduction à la Sécurité des Bases de Données (Page 208+)

Une base de données constitue un patrimoine stratégique pour toute organisation. Sa sécurisation consiste à mettre en œuvre un ensemble de mécanismes matériels et logiciels afin de la protéger contre toute altération, perte de données ou accès non autorisé. La sécurité repose sur trois piliers fondamentaux (le triptyque C-I-D) :

- **La Confidentialité** : Garantir que seules les personnes autorisées ont accès aux données sensibles.
- **L'Intégrité** : Veiller à ce que les données ne soient ni modifiées accidentellement ou malveillamment, restant ainsi exactes et cohérentes.
- **La Disponibilité (Durabilité)** : S'assurer que le système reste fonctionnel et accessible aux utilisateurs légitimes à tout moment.

1.2 Les Menaces et Vulnérabilités Majeures

Les systèmes de bases de données sont confrontés à deux types de menaces :

1. **Menaces Physiques** : Pannes de disques durs, coupures de courant, catastrophes naturelles, ou vols de serveurs.
2. **Menaces Logiques** :
 - **Usurpation d'identité** : Vol d'identifiants d'utilisateurs.
 - **Injections SQL** : Technique d'attaque où un utilisateur malveillant injecte du code SQL non prévu via les champs de saisie d'une application pour détourner le comportement du SGBD.
 - **Accès concurrents non contrôlés** : Modifications simultanées causant des pertes ou des incohérences de données.

1.3 Le Langage de Contrôle de Données (LCD)

Le LCD est la partie du SQL dédiée à la gestion de la sécurité d'accès. Il gère la création des comptes utilisateurs, l'attribution et le retrait de droits d'accès aux données.

1.3.1 1. Création d'Utilisateurs

La création d'un compte utilisateur s'effectue avec l'instruction suivante :

Syntaxe - Création d'Utilisateur

```
CREATE USER 'nom_utilisateur'@'machine' IDENTIFIED BY 'mot_de_passe';
```

Exemple : `CREATE USER 'correcteur'@'localhost' IDENTIFIED BY 'Bac2027Secure';`

1.3.2 2. La commande GRANT (Attribution de Privilèges)

Elle permet d'affecter des droits (ou privilèges) à un ou plusieurs utilisateurs.

Syntaxe - Commande GRANT

```
GRANT liste_privileges ON nom_table TO 'utilisateur'@'machine' [WITH GRANT OPTION];
```

Les privilèges d'objet les plus fréquents sont : `SELECT`, `INSERT`, `UPDATE`, `DELETE`.

La clause facultative `WITH GRANT OPTION` permet à l'utilisateur bénéficiaire de transmettre à son tour ces mêmes privilèges à d'autres utilisateurs.

1.3.3 3. La commande REVOKE (Retrait de Privilèges)

Elle permet de retirer des droits précédemment accordés.

Syntaxe - Commande REVOKE

```
REVOKE liste_privileges ON nom_table FROM 'utilisateur'@'machine';
```

Exemple de scénario :

1. Octroyer le droit de lecture et d'écriture :
`GRANT SELECT, INSERT ON NOTE TO 'secretaire'@'localhost';`
2. Retirer le droit d'insertion :
`REVOKE INSERT ON NOTE FROM 'secretaire'@'localhost';`

1.3.4 4. La notion de Rôle

Un rôle est un profil de sécurité qui regroupe plusieurs privilèges. Il simplifie grandement la gestion de la sécurité : au lieu de gérer les privilèges individuellement pour chaque utilisateur, on les attribue au rôle, puis on affecte ce rôle aux utilisateurs.

Syntaxe - Gestion des Rôles

```
CREATE ROLE 'nom_role';  
GRANT SELECT, UPDATE ON ELEVE TO 'nom_role';  
GRANT 'nom_role' TO 'utilisateur'@'machine';
```

1.4 Contrôle des Transactions et Concurrency (ACID)

Une transaction est une unité logique de traitement composée d'une suite d'instructions SQL qui s'exécutent de façon indissociable.

1.4.1 Les Propriétés ACID

Pour garantir la cohérence absolue d'une base de données, toute transaction doit respecter les quatre propriétés fondamentales suivantes :

- **Atomicité (A)** : Règle du “Tout ou Rien”. Soit toutes les opérations de la transaction sont enregistrées avec succès, soit aucune ne l’est.
- **Cohérence (C)** : La transaction fait passer la base d’un état cohérent à un autre état cohérent (respect de toutes les règles d’intégrité).
- **Isolation (I)** : Les modifications apportées par une transaction restent invisibles pour les autres transactions tant que celle-ci n’est pas validée.
- **Durabilité (D)** : Une fois la transaction validée, ses modifications sont enregistrées de façon permanente sur le disque et résistent à tout crash ou panne ultérieure.

1.4.2 Commandes de Contrôle de Transaction

- **START TRANSACTION;** (ou **BEGIN;**) : Débute la délimitation de la transaction.
- **COMMIT;** : Valide de manière définitive toutes les opérations effectuées depuis le début de la transaction.
- **ROLLBACK;** : Annule instantanément toutes les modifications temporaires effectuées par la transaction et ramène la base à son état initial.

Exemple Classique : Virement Bancaire d'un Compte A vers B

```
START TRANSACTION;
UPDATE COMPTE SET Solde = Solde - 500 WHERE IdCompte = 'A';
UPDATE COMPTE SET Solde = Solde + 500 WHERE IdCompte = 'B';
- Si les deux opérations s'exécutent avec succès :
COMMIT;
- En cas d'erreur ou d'interruption :
ROLLBACK;
```

1.5 Sauvegarde, Restauration et Audit

- **La Sauvegarde Logique (Dump)** : Exporte la structure et les données sous forme d’instructions SQL textuelles (.sql) permettant de reconstruire intégralement la base.
- **La Sauvegarde Physique** : Copie les fichiers binaires de la base sur un autre support physique (disque dur externe, cloud).
- **L’Audit (ou Journalisation)** : Consiste à enregistrer de manière sécurisée l’historique d’activité de la base de données afin de tracer et détecter d’éventuelles failles ou actions suspectes.

1.6 Modélisation Graphique TikZ : Architecture de Sécurité Multi-couche

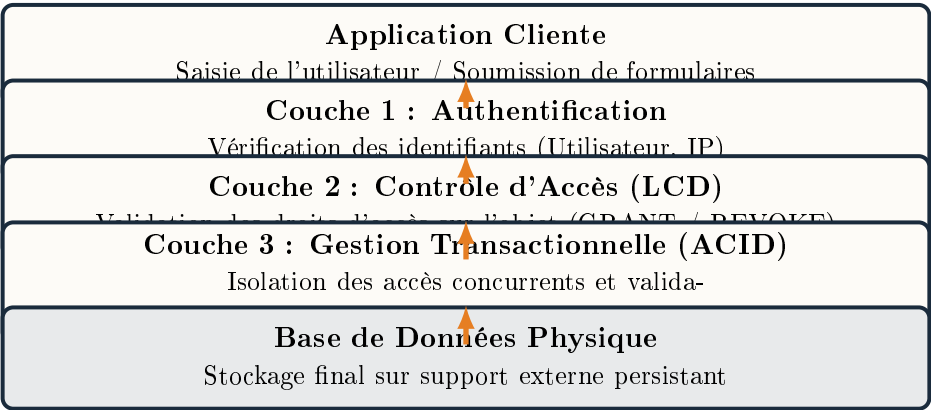


Figure 1.1: Architecture de sécurité multicouche d'un SGBD Moderne

Chapter 2

Fiche 2 : Le Recueil de Questions-Réponses (40 Flashcards)

Flashcard : Question 1

Question : Qu'est-ce que la sécurité des bases de données et quels sont ses objectifs principaux ?

Réponse : C'est l'ensemble des mesures techniques, logicielles, administratives et physiques prises pour préserver les données stockées contre les accès non autorisés, les altérations accidentelles ou malveillantes, et garantir leur disponibilité opérationnelle permanente.

Flashcard : Question 2

Question : Quels sont les trois piliers de la sécurité informatique d'une base de données (la triade C-I-D) ?

Réponse : C'est le socle de la sécurité de l'information : Confidentialité (protection contre les fuites), Intégrité (exactitude des informations sans altérations), et Disponibilité (accès garanti pour les utilisateurs autorisés).

Flashcard : Question 3

Question : Comment peut-on définir formellement la Confidentialité d'une base de données ?

Réponse : C'est la propriété garantissant que les données sensibles contenues dans la base ne sont pas divulguées à des personnes, des processus ou des machines non autorisés. Elle repose sur des mécanismes de contrôle d'accès stricts.

Flashcard : Question 4

Question : Qu'est-ce que l'Intégrité des données dans un SGBD ?

Réponse : C'est la garantie de l'exactitude, de la cohérence et de la validité des données tout au long de leur cycle de vie. Elle est assurée par le respect rigoureux des contraintes d'intégrité (PK, FK, CHECK, NOT NULL) par le SGBD.

Flashcard : Question 5

Question : Qu'est-ce que la Disponibilité des données d'une base ?

Réponse : C'est l'assurance que les utilisateurs légitimes ont un accès continu et sans entrave aux données dont ils ont besoin. Elle est menacée par les pannes matérielles, logicielles et les attaques de déni de service (DoS).

Flashcard : Question 6

Question : Qu'est-ce que la Durabilité d'une transaction validée ?

Réponse : C'est la capacité du système à garantir que les données modifiées et validées lors d'une transaction restent définitivement enregistrées, même en cas de crash complet du serveur ou de coupure de courant.

Flashcard : Question 7

Question : Donnez trois exemples de menaces physiques pesant sur une base de données.

Réponse :

1. Panne d'alimentation électrique générale.
2. Destruction physique ou vol des disques de stockage.
3. Catastrophes naturelles (inondations, incendies de salle de serveurs).

Flashcard : Question 8

Question : Donnez trois exemples de menaces logiques pesant sur une base de données.

Réponse :

1. Piratage ou usurpation de comptes de connexion.
2. Injections de requêtes SQL malveillantes par une application web trouée.
3. Anomalies de concurrence (mises à jour perdues) par manque d'isolation.

Flashcard : Question 9

Question : Qu'est-ce que le Langage de Contrôle de Données (LCD) ?

Réponse : C'est la branche du langage SQL dédiée à la sécurité d'accès. Elle se compose principalement des instructions d'octroi (GRANT) et de révocation (REVOKE) de privilèges de sécurité.

Flashcard : Question 10

Question : Quelle est la différence de rôle entre le LDD, le LMD et le LCD ?

Réponse : Le LDD définit et modifie la structure des tables (CREATE, ALTER). Le LMD manipule le contenu des tables (SELECT, INSERT, UPDATE). Le LCD administre les droits d'accès (GRANT, REVOKE).

Flashcard : Question 11

Question : Quel est l'effet de l'exécution d'une commande GRANT en SQL ?

Réponse : Elle attribue des privilèges spécifiques (d'interrogation, de modification ou de contrôle global) sur un ou plusieurs objets (tables, vues) de la base de données à un compte utilisateur ou un rôle.

Flashcard : Question 12

Question : Quel est l'effet de l'exécution d'une commande REVOKE en SQL ?

Réponse : Elle retire immédiatement des privilèges d'accès ou de manipulation préalablement affectés à un utilisateur ou à un groupe d'utilisateurs, bloquant instantanément leurs actions futures sur ces objets.

Flashcard : Question 13

Question : Quelle est la requête SQL pour accorder le privilège d'interrogation sur la table EXAMEN à l'utilisateur 'eleve'@'localhost' ?

Réponse :

```
GRANT SELECT ON EXAMEN TO 'eleve'@'localhost';
```

Flashcard : Question 14

Question : Quelle est la requête SQL pour retirer le privilège d'insertion sur la table USER à l'utilisateur 'visiteur'@'localhost' ?

Réponse :

```
REVOKE INSERT ON USER FROM 'visiteur'@'localhost';
```

Flashcard : Question 15

Question : Qu'est-ce qu'un privilège système ? Donnez un exemple.

Réponse : C'est un droit global au niveau du SGBD, non lié à une table spécifique. Exemple : CREATE USER, CREATE TABLE, ou BACKUP DATABASE. Il est généralement réservé au DBA.

Flashcard : Question 16

Question : Qu'est-ce qu'un privilège d'objet ? Donnez un exemple.

Réponse : C'est un droit d'action restreint à une ressource logique définie (une table ou une vue). Exemple : SELECT sur la table CLIENT, UPDATE sur la table COMPTE.

Flashcard : Question 17

Question : À quoi sert l'option WITH GRANT OPTION lors d'un GRANT ?

Réponse : Elle permet à l'utilisateur qui reçoit ce droit de le transmettre à d'autres utilisateurs. Si 'A' accorde un droit à 'B' avec cette option, 'B' peut accorder ce même droit à 'C'.

Flashcard : Question 18

Question : Comment le SGBD gère-t-il la révocation en chaîne de droits transmis via WITH GRANT OPTION ?

Réponse : Le SGBD applique généralement une révocation en cascade : si 'A' révoque le privilège de 'B', le droit transmis par 'B' à 'C' est automatiquement révoqué à son tour pour maintenir la cohérence de la chaîne de sécurité.

Flashcard : Question 19

Question : Qu'est-ce qu'un Rôle en sécurité de base de données ?

Réponse : C'est une entité logique ou "profil de sécurité" regroupant un ensemble cohérent de privilèges. Au lieu d'affecter des droits individuels à 50 utilisateurs, on associe les privilèges au rôle, puis on attribue ce rôle aux 50 utilisateurs.

Flashcard : Question 20

Question : Donnez la liste des instructions SQL pour créer un rôle, lui attribuer des droits et l'affecter à un utilisateur.

Réponse :

1. `CREATE ROLE nom_role;`
2. `GRANT privileges ON table TO nom_role;`
3. `GRANT nom_role TO utilisateur;`

Flashcard : Question 21

Question : Qu'est-ce qu'une transaction en bases de données ?

Réponse : C'est une suite d'opérations (lectures et écritures) formant une unité logique de traitement. Elle doit s'exécuter dans son intégralité (succès total) ou pas du tout (échec total et retour à l'état initial).

Flashcard : Question 22

Question : Qu'est-ce que la propriété d'Atomicité (le A dans ACID) ?

Réponse : C'est la règle du "Tout ou Rien". Si une transaction comporte 10 écritures et que la 10ème échoue, le SGBD effectue une annulation totale (ROLLBACK) des 9 écritures précédentes pour laisser la base intacte.

Flashcard : Question 23

Question : Qu'est-ce que la propriété de Cohérence (le C dans ACID) ?

Réponse : La transaction doit impérativement respecter toutes les contraintes de clés, de types et de validation. Si l'un des traitements viole une règle métier ou d'intégrité, la transaction entière échoue.

Flashcard : Question 24

Question : Qu'est-ce que la propriété d'Isolation (le I dans ACID) ?

Réponse : Chaque transaction doit s'exécuter comme si elle était seule sur le système. Les modifications non encore confirmées par un COMMIT restent strictement invisibles pour les autres transactions concurrentes.

Flashcard : Question 25

Question : Qu'est-ce que la propriété de Durabilité (le D dans ACID) ?

Réponse : Une fois le COMMIT exécuté, les modifications sont définitivement validées et physiquement écrites sur le disque dur. Elles survivent ainsi à toute coupure de courant ou crash immédiat du SGBD.

Flashcard : Question 26

Question : Quel est le rôle exact de la commande COMMIT en SQL ?

Réponse : Elle marque la fin d'une transaction réussie. Elle enregistre de manière irréversible toutes les modifications de données temporaires en base de données physique et libère les verrous de concurrence.

Flashcard : Question 27

Question : Quel est le rôle exact de la commande ROLLBACK en SQL ?

Réponse : Elle permet d'annuler immédiatement toutes les actions de modification (écritures, modifications, suppressions) d'une transaction échouée pour restaurer l'état exact de la base de données avant le début de la transaction.

Flashcard : Question 28

Question : En quoi consiste l'attaque par Injection SQL ?

Réponse : C'est une faille de sécurité applicative où un utilisateur malveillant détourne la structure logique d'une requête SQL en y insérant du code arbitraire via un formulaire de saisie web.

Flashcard : Question 29

Question : Quelle technique de programmation neutralise définitivement les Injections SQL ?

Réponse : Il faut utiliser systématiquement des Requêtes Paramétrées (ou requêtes préparées via prepare en Python ou TSQLQuery.Params en Lazarus) au lieu de construire les requêtes par concaténation de chaînes de caractères.

Flashcard : Question 30

Question : Qu'est-ce que le phénomène de "Lecture Sale" (Dirty Read) ?

Réponse : C'est un problème de concurrence où une transaction active lit des données qui ont été modifiées par une autre transaction qui n'a pas encore validé (COMMIT). Si cette dernière effectue un ROLLBACK, les données lues étaient fausses.

Flashcard : Question 31

Question : Comment un SGBD gère-t-il les accès simultanés concurrents à une même ligne ?

Réponse : Il utilise un gestionnaire de verrous (Locking Manager) qui bloque temporairement l'accès en écriture sur une ressource (une ligne ou une table) lorsqu'une transaction est en cours de modification de cette même ressource.

Flashcard : Question 32

Question : Quelle est la différence entre un verrou partagé (S) et un verrou exclusif (X) ?

Réponse : Un verrou partagé (S) permet à plusieurs transactions de lire la ressource simultanément. Un verrou exclusif (X) bloque tout accès en lecture ou écriture aux autres transactions pendant qu'une écriture s'effectue.

Flashcard : Question 33

Question : Qu'est-ce qu'une situation d'Interblocage (Deadlock) et comment le SGBD la résout-il ?

Réponse : C'est une situation de blocage mutuel où une transaction 'A' détient un verrou sur 'R1' et attend 'R2', tandis qu'une transaction 'B' détient un verrou sur 'R2' et attend 'R1'. Le SGBD doit intervenir en tuant l'une des transactions.

Flashcard : Question 34

Question : Qu'est-ce que le journal des transactions (Log File) et quel est son rôle ?

Réponse : C'est un fichier très sécurisé écrit séquentiellement par le SGBD avant chaque écriture en base de données. Il enregistre l'historique de chaque opération, permettant la restauration de la base après crash (Roll-forward).

Flashcard : Question 35

Question : Quelle est la différence entre une sauvegarde logique (Dump) et physique ?

Réponse : La sauvegarde logique génère un fichier texte d'instructions SQL (.sql) pour reconstruire la base. La sauvegarde physique copie directement les fichiers binaires du disque dur, étant plus rapide à restaurer mais liée au matériel.

Flashcard : Question 36

Question : Qu'est-ce qu'une sauvegarde incrémentale ?

Réponse : C'est un mécanisme de sauvegarde optimisé qui ne copie que les données qui ont été modifiées depuis la toute dernière sauvegarde (complète ou incrémentale), économisant énormément de temps et d'espace disque.

Flashcard : Question 37

Question : Comment l'utilisation de Vues (VIEW) renforce-t-elle la sécurité des données ?

Réponse : Une vue est une table virtuelle masquant certaines lignes ou colonnes confidentielles. On peut accorder à un utilisateur un droit d'accès (SELECT) uniquement sur la vue, protégeant ainsi la table physique sous-jacente.

Flashcard : Question 38

Question : À quoi sert le chiffrement (Encryption) d'une base de données ?

Réponse : C'est la transformation des informations sensibles (mots de passe, numéros de carte de crédit) sous forme de texte inintelligible à l'aide d'un algorithme cryptographique. Les données restent protégées même en cas de vol du disque dur.

Flashcard : Question 39

Question : Quel est le rôle principal de l'Administrateur de Base de Données (DBA) ?

Réponse : Le DBA (Database Administrator) est le garant de la sécurité de la base. Il gère les comptes, crée les rôles, planifie les sauvegardes automatiques et effectue la restauration en cas de panne physique ou logique.

Flashcard : Question 40

Question : En quoi consiste l'audit de sécurité d'une base de données ?

Réponse : C'est le processus consistant à analyser l'historique d'activité (logs d'accès) pour repérer d'éventuelles anomalies : tentatives de connexion infructueuses répétées, exécutions de requêtes anormales ou modifications de droits non documentées.

Chapter 3

Fiche 3 : Quiz d'Évaluation & Fiches Mémo

3.1 Quiz d'Évaluation : 10 Questions types du Baccalauréat

3.1.1 Question 1 — QCM

Quelle instruction SQL permet d'accorder à l'utilisateur 'admin_scolaire' le droit de modifier les lignes de la table NOTE ?

- A) ALLOW UPDATE ON NOTE TO admin_scolaire;
- B) GRANT UPDATE ON NOTE TO admin_scolaire;
- C) GRANT SELECT, ALTER ON NOTE TO admin_scolaire;

Correction & Justification :

La bonne réponse est **B**. L'instruction SQL officielle pour attribuer des privilèges d'accès est **GRANT**. L'option A est une commande inexistante. L'option C attribue le droit de consultation (**SELECT**) et de modification structurelle de la table (**ALTER**), ce qui dépasse le simple droit de mise à jour de données.

3.1.2 Question 2 — Vrai ou Faux

La clause **WITH GRANT OPTION** permet à un utilisateur de retirer des droits à d'autres utilisateurs.

Correction & Justification :

FAUX. La clause **WITH GRANT OPTION** permet uniquement de transmettre (octroyer) les privilèges reçus à d'autres comptes de la base. Le retrait des privilèges s'effectue obligatoirement avec la commande **REVOKE**, exécutée par le propriétaire d'origine ou l'administrateur (DBA).

3.1.3 Question 3 — QCM

En cas de coupure de courant pendant l'exécution d'une transaction financière, quelle propriété ACID garantit que les comptes ne restent pas incohérents ?

- A) L'Isolation
- B) L'Atomicité
- C) Le Chiffrement

Correction & Justification :

La bonne réponse est **B**. L'Atomicité garantit la règle du "Tout ou Rien". Si la transaction est interrompue à cause d'une panne d'alimentation, toutes les modifications déjà effectuées sont immédiatement annulées par le SGBD lors du redémarrage (opération de **ROLLBACK** automatique basée sur le journal de transactions).

3.1.4 Question 4 — Vrai ou Faux

Une transaction validée par un **COMMIT** peut être annulée ultérieurement à l'aide de l'instruction **ROLLBACK**.

Correction & Justification :

FAUX. L'instruction `COMMIT` valide de manière permanente et irréversible les données sur le support physique (propriété de Durabilité). Dès lors que le `COMMIT` est acquitté, l'exécution d'un `ROLLBACK` n'a plus aucun effet sur cette transaction terminée.

3.1.5 Question 5 — QCM

Comment appelle-t-on le concept permettant d'associer un lot de privilèges à un profil nommé pour simplifier l'administration de la sécurité ?

- A) Une Vue
- B) Un Utilisateur
- C) Un Rôle

Correction & Justification :

La bonne réponse est **C**. Un Rôle est un conteneur de privilèges destiné à être affecté de manière groupée à plusieurs utilisateurs partageant la même fonction métier (ex: correcteur, secrétaire).

3.1.6 Question 6 — Vrai ou Faux

Le Langage de Contrôle de Données (LCD) inclut les instructions `INSERT` et `DELETE`.

Correction & Justification :

FAUX. Les instructions `INSERT` et `DELETE` appartiennent au Langage de Manipulation de Données (LMD). Le LCD ne comprend que les instructions d'octroi et de retrait de privilèges (`GRANT` et `REVOKE`).

3.1.7 Question 7 — QCM

Quelle vulnérabilité applicative permet à un hacker d'exécuter des requêtes destructrices en détournant les champs de saisie de l'application ?

- A) Une usure de disque
- B) Une injection SQL
- C) Un interblocage (Deadlock)

Correction & Justification :

La bonne réponse est **B**. L'Injection SQL est la faille de sécurité majeure découlant d'un manque de filtrage des saisies utilisateurs transmises directement au moteur d'exécution SQL.

3.1.8 Question 8 — Vrai ou Faux

Les requêtes paramétrées permettent de neutraliser efficacement les attaques de type Injection SQL.

Correction & Justification :

VRAI. En séparant le code logique de la requête SQL des paramètres de données saisis par l'utilisateur, le moteur SQL traite les entrées comme de simples constantes, éliminant tout risque d'interprétation de caractères spéciaux (comme les guillemets simples ' ou `OR 1=1`).

3.1.9 Question 9 — QCM

Quelle commande permet de créer un nouveau profil de sécurité nommé 'correcteur' ?

- A) `CREATE USER correcteur;`
- B) `CREATE ROLE correcteur;`
- C) `NEW ROLE correcteur;`

Correction & Justification :

La bonne réponse est **B**. L'instruction standard pour définir un nouveau rôle de sécurité en SQL est `CREATE ROLE`. L'option A sert à créer un compte utilisateur physique. L'option C est syntaxiquement incorrecte.

3.1.10 Question 10 — Vrai ou Faux

Une sauvegarde logique (Dump) copie directement les fichiers de données binaires du SGBD depuis le disque dur.

Correction & Justification :

FAUX. Une sauvegarde logique extrait la structure et les lignes sous forme de script de requêtes SQL (fichier .sql). C'est la sauvegarde physique qui consiste à copier les fichiers binaires réels de la base sur un autre support de stockage.

3.2 Mémento de Synthèse Universelle

Commande SQL	Type	Rôle principal en Sécurité / Transaction
CREATE USER	LCD / Syst.	Définit un nouvel utilisateur authentifié avec son mot de passe.
GRANT	LCD	Accorde des droits d'accès ou de manipulation sur des objets.
REVOKE	LCD	Retire des droits d'accès préalablement accordés à un utilisateur.
CREATE ROLE	LCD / Syst.	Définit un rôle logique pour regrouper des privilèges.
START TRANSACTION	Transaction	Début une transaction logique unifiée (Atomicité).
COMMIT	Transaction	Valide définitivement et physiquement les données (Durabilité).
ROLLBACK	Transaction	Annule toutes les modifications temporaires effectuées (Atomicité).

Table 3.1: Synthèse des instructions SQL LCD & Transactionnelles

3.3 Les 5 Règles d'Or pour la Sécurité au Baccalauréat

1. **Ne jamais omettre le point-virgule (;)** : C'est le délimiteur obligatoire des instructions SQL lors des examens écrits.
2. **Toujours séparer l'utilisateur de sa machine** : En SQL d'accès, la désignation complète d'un utilisateur associe toujours son nom et son hôte de connexion (ex: `'user'@'localhost'`).
3. **Mettre des guillemets sur les chaînes de caractères** : Les chaînes de caractères en SQL s'encadrent toujours de guillemets simples (apostrophes).
4. **Ne pas confondre LMD (DELETE) et LDD (DROP)** : Pour supprimer les lignes d'une table, utilisez `DELETE FROM table`; pour détruire entièrement la table, utilisez `DROP TABLE table`.
5. **Savoir que WITH GRANT OPTION ne s'utilise pas avec REVOKE** : Pour révoquer, on n'utilise jamais d'option de transmission. La commande standard est uniquement `REVOKE ... FROM ...`.